

VENDOR MANAGEMENT POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Vendor Management Policy
Document ID	POL-VM-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC2.3, CC3.2, CC9.2 and CC6.1, and GDPR Articles 28 and 32. Reviews are annual or triggered by a change in the arrangement, rather than run on a shorter calendar.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE	5
2 SCOPE	5
3 ROLES AND DEFINITIONS.....	5
4 TERMINOLOGY	5
5 TIERING.....	6
6 BEFORE A VENDOR IS USED	6
7 SUB-PROCESSORS AND CLIENT OBLIGATIONS	7
8 WHILE A VENDOR IS IN USE	7
9 WHEN A VENDOR LEAVES	7
10 RECORDS	8
11 EXCEPTIONS.....	8
12 REFERENCE	8
13 DOCUMENT POLICY HISTORY.....	8

1 Overview and Purpose

PromptHalo Technologies (“the Company”) runs almost entirely on other people's software. AWS, Google Workspace, GitHub and the model providers hold or process client information, and the Company's security depends materially on theirs.

This Policy says how a vendor is assessed before it is used, what is watched afterwards, and what happens when the relationship ends. It is written so that the effort lands on the handful of vendors that matter rather than being spread evenly across every subscription.

2 Scope

This Policy covers any third party that stores, processes or can reach Company or client information, or on which the Company's service materially depends. That is a short list, and keeping it short is deliberate.

A tool that touches nothing above Internal is recorded and left there. The assessment effort below applies only where client information or service availability is involved.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. The Accountable Party approves a vendor before it is used, maintains the register and the sub-processor list, and decides whether a change in a vendor's terms needs action. [SOC 2: CC9.2, CC3.2]
5. Each vendor has a named internal owner — usually whoever asked for it — responsible for knowing what it is used for and telling the Accountable Party when those changes. [SOC 2: CC9.2]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
3. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
4. **Critical vendor** — a vendor whose failure would stop the Company delivering its service, or whose compromise would expose client information.

- 36 5. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
- 37 6. **Fourth party** — a subcontractor of a vendor, on which the Company depends indirectly.
- 38 7. **Information Security Steering Committee** — the Company's oversight body for information
39 security. At the Company's current size, the Committee comprises the CEO, and every reference
40 in this policy to a decision, approval, review or report of the Committee is satisfied by a dated
41 written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2,
42 CC1.3]
- 43 8. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of
44 the Company.
- 45 9. **Security Officer** — the individual accountable for day-to-day operation of the security program.
- 46 10. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that
47 requires risk reassessment.
- 48 11. **Sub-processor** — a vendor that processes personal data on behalf of a client, and which the
49 client must usually be told about.
- 50 12. **Subservice organization** — a third party whose controls the Company relies upon and which is
51 carved out of the Company's report.
- 52 13. **Vendor** — any third-party supplying software, infrastructure or services to the Company.

53 **5 Tiering**

54 Three tiers, decided by what the vendor can reach rather than what it costs.

- 55 1. **Critical** — holds or processes client information, or the service stops without it. AWS, Google
56 Workspace, GitHub and any model provider in the delivery path sit here. Expect five to eight
57 vendors in this tier. [SOC 2: CC9.2, CC3.2]
- 58 2. **Standard** — holds Company information but not client information, and the service survives its
59 loss. [SOC 2: CC9.2]
- 60 3. **Incidental** — touches nothing above Internal. Recorded in the register; no assessment required.
61 [SOC 2: CC9.2]
- 62 4. **A vendor moving up a tier** — a tool given access to client data, or a pilot becoming part of
63 delivery — is reassessed before it does. That reassessment is the control, not a calendar date.
64 [SOC 2: CC3.4, CC9.2]

65 **6 Before a Vendor Is Used**

- 66 1. Critical vendors are assessed before use: what they hold, where they process it, whether the
67 Company can get its data back, and what independent assurance exists. A current SOC 2 or ISO
68 27001 report is accepted as that assurance rather than a questionnaire. [SOC 2: CC9.2, CC3.2]

2. Where a vendor publishes a compliance report, the complementary user entity controls in it are read and the ones that fall to the Company are recorded. The assurance is only worth what the Company does on its own side. [SOC 2: CC9.2]
3. Standard vendors are recorded with their owner, purpose and data classification. No questionnaire is sent and none is expected — at this size a questionnaire nobody reads is theatre. [SOC 2: CC9.2]
4. Contract terms for critical vendors cover confidentiality, security, breach notification and return or deletion of data at the end. Where the Company cannot negotiate terms — which is the normal case with large providers — the published terms are read and the position accepted knowingly and recorded. [SOC 2: CC9.2, CC2.3 · GDPR Art. 28]

7 Sub-processors and Client Obligations

1. Vendors that process client personal data are recorded on the sub-processor list, which is the list the Company publishes or provides to clients under its agreements. [SOC 2: CC9.2, CC2.3 · GDPR Art. 28]
2. Adding a sub-processor trigger whatever notice the client agreements require, before the sub-processor starts processing. The periods are in the notification matrix under the Incident Response Policy rather than restated here. [SOC 2: CC2.3 · GDPR Art. 28]
3. Fourth parties are considered where a critical vendor depends materially on one — a model provider running on another cloud, for instance. The Company does not assess them directly; it records the dependency, so it is visible. [SOC 2: CC9.2, CC3.2]

8 While a Vendor Is in Use

1. Critical vendors are reviewed annually: the assurance report refreshed, the terms rechecked, the owner confirmed, and the tier confirmed still right. One sitting cover all of them. [SOC 2: CC9.2, CC3.2]
2. A review also happens when something changes — a provider announces new terms or retention behavior, a breach is disclosed, an assurance report is qualified, or the Company starts using the vendor differently. The trigger matters more than the calendar. [SOC 2: CC3.4, CC9.2]
3. Shadow vendors are found by reconciling card and subscription spend against the register once a year. An unmanaged service usually appears on a statement before it appears anywhere else. [SOC 2: CC9.2, CC2.1]
4. Third-party application connections to Google Workspace and GitHub are restricted by allow-list and reviewed annually, under the Asset Management Policy. [SOC 2: CC6.1, CC9.2]

9 When a Vendor Leaves

1. Offboarding revokes the vendor's access, retrieves or confirms deletion of Company and client data, and records the confirmation. A vendor that cannot confirm deletion is recorded as a residual risk rather than assumed clean. [SOC 2: CC9.2, CC6.5]

2. Where the vendor was a sub-processor, the client notification obligations are checked before the relationship ends, not after. [SOC 2: CC2.3 · GDPR Art. 28]
3. The register entry is closed with the date and the reason rather than deleted, so the population for a period remains complete. [SOC 2: CC9.2, CC2.1]

10 Records

1. The vendor registers with tier, owner, purpose and data classification. [SOC 2: CC9.2]
2. Assurance reports for critical vendors and the recorded complementary user entity controls. [SOC 2: CC9.2]
3. The sub-processor list and any client notifications made. [SOC 2: CC2.3]
4. The annual review record covering all critical vendors in one sitting. [SOC 2: CC9.2]
5. Offboarding confirmations, including any that could not be obtained. [SOC 2: CC9.2]

11 Exceptions

Where a vendor cannot meet a requirement of this Policy — no assurance report, or terms the Company cannot negotiate — the position is recorded by the Accountable Party with the compensating measure and a review date. Accepting a large provider's published terms is the ordinary case and is recorded once rather than argued each year.

12 Reference

1. SOC 2 Trust Services Criteria, Security category [CC2.3, CC3.2, CC6.1, CC9.2]
2. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
3. POL-RSK-001 Risk Management Policy [SOC 2: CC3.2]
4. POL-AI-001 Artificial Intelligence Governance Policy [SOC 2: CC9.2]
5. POL-AM-001 Asset Management Policy [SOC 2: CC6.1]
6. POL-IRP-001 Incident Response Policy [SOC 2: CC2.3]
7. POL-DRD-001 Data Retention and Disposal Policy [SOC 2: CC6.5]
8. EU General Data Protection Regulation, Articles 28 and 32

13 Document Policy History

Version	Date	Description
1.0	August 18, 2026	Initial policy release